Data leak worksheet

Incident summary: *A customer success representative received access to a folder of internal documents from a manager. It contained files associated with a new product offering, including customer analytics and marketing materials. The manager forgot to unshare the folder. Later, the representative copied a link to the marketing materials to share with a business partner during a sales call. Instead, the representative shared a link to the entire folder. During the sales call, the business partner received the link to internal documents and posted it to their social media page.*

Control	Least privilege
Issue(s)	*What factors contributed to the information leak?* The principle of least privilege was not maintained as the customer success representative should not have had access to the folder and the representative should not have been able to share the folder with the business partner either.
Review	*What does NIST SP 800-53: AC-6 address?* The principle of least privilege is a security control that means only minimal access and authorisation should be given to users which is necessary for them to complete their tasks. This prevents users from having a higher privilege to information then they actually need in order to complete their objectives.
Recommendation(s)	*How might the principle of least privilege be improved at the company?* • Restrict access to sensitive resources based on user role. • Automatically revoke access to information after a period of time.

Justification	*How might these improvements address the issues?* Restricting access to sensitive resources based on user role will prevent important information being accessed by users who do not need to access it. In this instance if the representative didn't have access to the sensitive information in the folder in the first place then they would not have been able to share it. Automatically revoking access to information after a period of time - this would have helped prevent the leak because if a folder is accidentally shared with someone who should not have access to the information then their access will be cut off by a time limit instead of it being on-going access.

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: *Data security*	PR.DS-5: *Protections against data leaks*.	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	**Least Privilege**
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: • Restrict access to sensitive resources based on user role. • Automatically revoke access to information after a period of time. • Keep activity logs of provisioned user accounts. • Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.